Monthly Intelligence Dispatch

August 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB researchers released a report about attacks against Russia by the Chinese state-sponsored groups **TaskMasters** and **TA428**. These groups may have been behind the attacks against Russian federal executive authorities in 2020.
- A post on a hacker forum emerged about the sale of personal data belonging to nearly **100 million** customers of **T-Mobile**, one of the largest mobile operators in the world.
- A new threat group called **BlackMatter** is linked to **DarkSide** and **Revil**, it has been found.
- Customers of **Dodo Pizza** and **Papa John's** come across fake website clones: for the first time, the businesses have estimated the damage from attacks against their brands.
- After the opening of the 2020 Summer Olympic Games in Tokyo, CERT-GIB discovered dangerous resources that imitated live broadcasts of sporting events and redirected users to fraudulent websites.
- Taiwanese motherboard maker **Gigabyte** was hit by the **RansomEXX** threat actors.
- The cosmetics company **Oriflame** fell victim to a series of attacks, which were followed by passport scans of the company's 1.3 million Russian customers being leaked online.
- The Japanese cryptocurrency exchange **Liquid** fell victim to a hacker attack.

TaskMasters and TA428

In mid-May 2021, experts at **SOLAR JSOC** and the National Computer Incident Response & Coordination Center (**NCIRCC**) released a joint report about a series of targeted attacks detected in 2020. According to the report, the attackers targeted Russian federal executive authorities.

While analyzing the report, **Anastasia Tikhonova** (Head of APT Research at Group-IB) and **Dmitry Kupin** (Senior Malware Analyst) noticed that they had already come across similar tools in earlier attacks.

Chinese APTs are one of the most numerous and aggressive hacker communities. Several dozen groups conduct attacks in countries all over the world, including Russia. Hackers mostly target state agencies, industrial facilities, military contractors, and research institutes. The main objective is espionage: attackers gain access to confidential data and attempt to hide their presence for as long as possible. There have been cases when attackers successfully persisted in the victim's network for several years.

Group-IB's researchers have arrived at some interesting conclusions about what Chinese groups could be behind the attacks against Russian federal executive authorities in 2020, what tools they used, and how their malware has evolved since.

Group-IB experts believe that the situation is either the Chinese hacker groups **TA428** and **TaskMasters** attacked Russian federal executive authorities in 2020 or there is one united Chinese hacker group made up of different units.

GhostEmperor

According to Kaspersky, Q2 2021 saw an increase in sophisticated targeted attacks against **Microsoft Exchange** servers. In particular, Chinese-speaking hackers took advantage of Microsoft Exchange vulnerabilities to conduct an espionage campaign called GhostEmperor. The group has been using an advanced toolset since July 2020 and has mostly focused on targets in Southeast Asia, including government entities and telecom companies.

T-Mobile

A post on a hacker forum emerged about the sale of personal data belonging to nearly **100 million** customers of **T-Mobile**, one of the largest mobile operators in the world. The seller claims to have hacked into T-Mobile's production, staging, and development servers two weeks ago, including an **Oracle** database server containing customer data. They then stole all data from there. The threat actor estimated the entire dump at 6 Bitcoin (about $300,000 with the current exchange rate). The seller claims that the database contains personal information about 100 million people, including their IMSI, IMEI, phone numbers, customer names, and security PINs, as well as birth dates, driver's license numbers, and social security numbers for 30 million people. John Binns, 21, has taken responsibility for the breach. In an interview for the Wall Street Journal, Binns said that he did not have to do anything sophisticated and that he used available tools.

Oriflame

The cosmetics company Oriflame fell victim to a series of attacks, which were followed by passport scans of the company’s 1.3 million Russian customers being leaked online. They were put up for sale on **RaidForums**, a hacker forum. Oriflame was hit by hacker attacks on July 31 and August 1.

BlackMatter

Group-IB experts analyzed risks posed by a threat group called BlackMatter, which appeared on the scene in late July when posts started being published on hacker forums about seeking to recruit partners and willingness to pay **$100,000** for access to compromised networks of companies with annual revenues of more than $100 million. In August, BlackMatter gave its first interview, a talk with Recorded Future analyst Dmitry Smilyanets in Russian. According to the group's representative, before developing their own malware, they studied the ransomware of groups such as LockBit, REvil, and DarkSide and employed the best functionality from each piece of malware to create their own tool. Group-IB researchers analyzed a sample of the mentioned ransomware and concluded that it highly resembled its predecessors, DarkSide and REvil in terms of code and functionality.

After a series of successful and high-profile attacks, these two groups dropped out of sight and practically disappeared from researchers' radars.

DemonWare

Hackers started paying employees for installing ransomware on their companies' computers. Researchers at Abnormal Security say that threat actors trick employees into installing the DemonWare ransomware in their organization's network promising to share part of the ransom with them. The ransomware, also known as **Black Kingdom** and **DEMON**, has very simple internal code. **DemonWare** can be downloaded from GitHub for free, because the author made it publicly available.

RansomEXX

Taiwanese motherboard maker **Gigabyte** has been hit by the RansomEXX threat actors, who threaten to publish **112 GB** worth of stolen data unless a ransom is paid. Gigabyte confirmed to the media that they had suffered a cyberattack, but the company stressed that the incident only affected a small number of servers. After detecting the abnormal activity on their network, they had shut down their IT systems and notified law enforcement.

All World Cards

On August 2, Group-IB's Threat Intelligence & Attribution system detected an unconventional post on several carding forums. A user, nicknamed AW_cards posted links to a file containing 1 million pieces of stolen payment records. The file, offered for free, contained compromised card details from over 1,000 banks in more than 100 countries, including India, Mexico, the US, Australia, and Brazil. The post immediately sparked Group-IB researchers' interest, because cybercriminals in the carding community rarely offer so many cards for free. It is especially unusual for a previously unknown market player, the more so because the huge batch of compromised cards had not appeared on other underground forums. Further research revealed that the post was nothing but a very bold ad to scale up the user base of the newly established card shop All World Cards, which joined the carding market in May 2021.

Mastercard and Maestro

Researchers at ETH Zurich, a Swiss university, discovered a way of bypassing PIN codes on contactless **Mastercard** and **Maestro** cards. The discovered flaw made it possible for threat actors to use stolen cards to make large purchases. The idea is that the hacker will position themselves between a stolen card and a POS (point-of-sale) terminal in what security researchers would normally call a man-in-the-middle scenario. To achieve this, an attacker would need: a stolen card, two Android smartphones, and a custom-made Android app that can tamper with a transaction's fields. The app is installed on both smartphones, which will act as emulators. One smartphone will be placed near the stolen card and act as a POS emulator, tricking the card into initiating a transaction and sharing its details, while the second smartphone will act as a card emulator and be used by the threat actor to feed modified transaction details to a real-life POS terminal inside a store. From a POS operator's point of view, the attack looks as if a customer is paying with their mobile phone. Such bugs may result in mass exploitation in the future.

Liquid

The Japanese cryptocurrency exchange Liquid fell victim to a hacker attack. Unidentified threat actors breached the exchange's servers and stole crypto assets whose value is estimated at $94 million with the current exchange rates. Liquid says the theft occurred after threat actors accessed the exchange's hot wallets, which are used for daily transactions. At the moment, Liquid is moving the rest of the assets to their cold wallet and is trying to block the hackers' access to their network.

After the opening of the 2020 Summer Olympic Games in Tokyo, CERT-GIB discovered dangerous resources that imitated live broadcasts of sporting events and redirected users to fraudulent websites. CERT-GIB has identified 120 similar resources that either have been or may be used to host broadcasts and engage in phishing. Websites that hackers compromised as part of this campaign included those of institutes, charities, online shops, etc.

Dodo Piza and Papa John's

Popular pizza chains Dodo Pizza and Papa John's admitted that their customers often come across fake website clones when trying to order food online. The founder of Dodo Pizza, Fyodor Ovchinnikov, said that over the past three months, the company had faced an actual attack: **158** phishing websites were blocked in May–July, with damage to customers amounting to about **$38,000**. Papa John's estimated damage from fraudsters at about **$20,400** in six months. "To avoid falling victim to threat actors, customers should carefully check the domain names of websites they are trying to visit and generally be cautious about messages advertising promotion offers and discounts," Yevgeny Egorov, lead analyst in Group-IB's Digital Risk Protection team, told Gazeta.Ru.

Standup

Fraudsters started taking advantage of standups to trick Russian residents. Security specialists say that threat actors create fake websites that claim to be selling tickets for standup shows. The scheme also involves fake payment resources whose purpose is to collect bank card data. Specialists at the company Searchinform reported an increase in the number of fake websites in the Russian-speaking part of the Internet. They observed about 20 malicious websites relating to comedy and standup in the .ru domain zone. Complaints from users about such resources started as early as March.

Hancitor

As early as spring 2021, Group-IB's Threat Intelligence analysts discovered traces of a malicious campaign involving the Hancitor loader. The analysts were interested in the loader's unusual distribution pattern, which was later described by researchers at Unit 42 and McAfee as a new technique for hiding documents containing malicious links and attachments from web scanners' radars. However, according to Group-IB analysts, a similar technique is used to distribute malware such as Campo Loader, IcedID, QBot, SocGholish, and Buer Loader. Group-IB experts Victor Okorokov and Nikita Rostovtsev discovered at least 3,000 users who had been targeted by separate malicious campaigns involving a similar technique. Analysis of the list of targets revealed two most active campaigns: one targeted individuals in Belgium and the other targeted companies, corporations, universities, and government organizations in the United States.

Telegram

A Trojan called FatalRAT is distributed via Telegram. Security experts say that threat actors look for victims through the messaging app's channels and chats. The virus is contained in links. By using the virus, the hackers infect devices and gain full access to users' actions. Threat actors are also able to make changes to the infected system without the owner's knowledge.

LockBit

The LockBit ransomware acquired new functionality. It can now automate the encryption of a Windows domain by using Active Directory group policies. In addition, the ransomware can now easily disable Windows Defender right before launching the encryption of an entire network. Further, infected systems immediately print out a ransom note on all printers connected to the affected network.

Arrests and sentences

RIA

Estonian authorities announced that on July 23, 2021 a local resident who had used a vulnerability to gain access to a government database was arrested. The suspect downloaded 286,438 photos of people and the attack was discovered because of an increase in the number of queries. It was reported that the attack occurred in early July. The identity of the attacker was not disclosed, and he was only identified as a Tallinn-based male. Officials said the suspect discovered a vulnerability in a database managed by the Information System Authority (RIA). The database usually checked with five different subsystems before returning a query to display a user's government ID photo.

HD VideoBox

Ukrainian police arrested the owner of the pirate streaming service HD VideoBox, which had been very popular among Russian citizens. The service was created by a 36-year-old Ukrainian citizen from Lviv. A criminal case was opened against them and they are now facing up to six years in prison.

Forecasts and warnings

- Even though the **BlackMatter** affiliate program just started, the threat actors already published information about one of their victims on their website. As usual, affiliates download confidential data before deploying ransomware. It is too early to get into the technical details, especially in the context of tactics, techniques, and procedures, since a lot depends on the threat actors who are going to be working with this affiliate program according to the ransomware as a service (RaaS) model.
- Group-IB specialists' analysis of a sample of new ransomware revealed clear links between BlackMatter and samples of DarkSide and REvil (especially DarkSide). It is not possible to say with full confidence whether the same team of developers is behind all three pieces of ransomware, but it is clear that DarkSide and REvil have now been replaced by BlackMatter, which is no less sophisticated. Read more about it in our blog post.
- Because the start of the 2020 Summer Olympic Games in Tokyo was followed by the appearance of websites that were disguised as live broadcasts of sporting events and redirected users to fraudulent websites, Group-IB experts recommend watching sporting broadcasts on official resources only, being wary of promotion offers and lottery games, and avoiding entering bank card and personal data on suspicious websites.
- To avoid falling victim to threat actors, customers should carefully check the domain names of websites they try to visit and generally be cautious about messages advertising promotion offers and discounts. Be generally very cautious about buying things on unknown websites: if you are unsure, it is better to check what the official website is. A good idea would be to visit links from verified social media accounts. If you have not been able to find anything, it is better to look for a different website or not make the purchase or order at all.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com